

---

WHITE PAPER · PORTFOLIO & AI GOVERNANCE

# AI Usage Belongs in Workflow Governance

How to govern AI where work happens and scale controls with consequence

---

**Marco Policani**

Enterprise Portfolio · PMO · AI Operating Governance

[policani.net](https://policani.net) · [linkedin.com/in/marcpolicani](https://linkedin.com/in/marcpolicani)

July 2026

## EXECUTIVE SUMMARY

**A license identifies who may use an AI tool. A usage-control record identifies the workflow it is used in, its limits, and the owner accountable for it.**

Two uses of the same approved AI account can carry very different consequences. The license record cannot show how much people depend on the output, what the AI is allowed to do, who reviews it, or how a mistake would be contained.

- 01** Keep low-stakes drafting light, and put the fuller record on any workflow where AI output feeds a decision or takes an action.
- 02** Require one short usage-control record before a workflow can influence a decision or take an action. It answers six questions: what work AI may do, what is monitored, what limits contain a mistake, what evidence is kept, who reviews and can stop it, and when the use is reviewed again.
- 03** Tighten the answers as the consequence of an error, dependence on the output, or the AI's autonomy rises.

## One AI account can carry two different risks

Your organization has approved an AI tool and wants more people to use it. The access decision looks responsible: an approved vendor, sign-on controls, an acceptable-use policy, and licenses assigned to the right employees. Fewer hurdles can help people learn where the tool is useful. A sanctioned option is also better than forcing useful work into personal accounts that the organization cannot see.

Now follow two uses of the same account. One employee asks the tool to draft an internal meeting note. Another depends on it in a workflow that affects a customer, or allows an agent to trigger a downstream action. The license record looks the same in both cases. It cannot reveal the consequence of an error or how much authority the AI had. It also leaves the review point and stop authority unknown.

That is the problem facing the CIO or AI-governance leader asked to expand access. A blanket policy creates two bad choices. Heavy approval on every low-stakes use

can drive people around the sanctioned path. Light controls on every use allow high-stakes work to proceed without evidence, limits, escalation, or ownership. The access decision cannot distinguish the work that needs few hurdles from the work that needs a stronger control. Underneath the dilemma is the oldest principle in risk management, quietly skipped for AI: control intensity should scale with the consequence of the activity, not the tool that performs it. Consequence lives in the workflow, which is why the account — a record of access — is the wrong unit of governance.

The stakes become more concrete when AI can act. McKinsey's agentic-era analysis expands the risk from wrong statements to wrong actions, tool misuse, and operation beyond guardrails.[1] A drafting error can be corrected before use. An unlimited action may reach another system or person before anyone knows it happened.

---

## Build the missing record around consequence

Account approval opens the capability; a separate workflow record must name the work AI may perform, the decision or action it can influence, the evidence it must leave, and the owner who can stop it.

That separation resolves the apparent choice between open access and blanket restriction. The organization can keep a low-stakes drafting path light while applying stronger controls to a workflow that influences a high-stakes decision or performs an external action.

NIST supplies the context-of-use frame; the six controls in this paper are my operating translation. The AI Risk Management Framework organizes risk work through GOVERN, MAP, MEASURE, and MANAGE. It treats context of use as material to the risk decision.[2] For each high-stakes workflow, leaders therefore need to define what AI may do, what evidence it must leave, and which limits contain a mistake. They must also name the point where a human takes over and the person who owns the use. The ISO/IEC 42001 management-system standard sets requirements for establishing, maintaining, and continually improving an AI management system in organizations that provide or use AI.[4]

The unit also keeps governance out of individual prompt surveillance. Leaders focus visibility on high-stakes workflows and how the AI is used. That focus preserves room for experimentation while giving the organization a way to recognize where dependence on the output, or the AI's autonomy, has raised the stakes.

## Six controls make a workflow governable

Each high-stakes AI-enabled workflow needs six controls. Together they make the record usable.

### EXHIBIT 1

#### Six controls for high-stakes workflows

**1. Scoped access**

Define the workflow and the work AI may perform.

**2. Monitoring**

Make actual use visible at the workflow level.

**3. Usage limits**

Bound volume, rate, or autonomy so a mistake stays contained.

**4. Evidence and logging**

Keep enough of a record to reconstruct what the AI did and what a person depended on.

**5. Escalation and review**

Route uncertainty and limit breaches to a named owner who can stop the use.

**6. Review of usage**

Revisit the workflow as its use changes, and raise or lower controls.

Monitoring is the practical starting point because it shows whether the controls work and whether dependence has changed. The NIST Generative AI Profile calls for continuous monitoring and structured feedback. It also treats incident response and the human-AI configuration as operating concerns across the lifecycle.[3] Without visibility, a leader cannot tell whether a limit works or whether people now depend on an output in a new way. Yesterday's drafting aid may already feed a decision.

This monitoring belongs at the workflow level. A customer-impacting use might track AI-triggered actions, human overrides, limit breaches, and escalations. Those signals expose gaps in the sanctioned path and show when dependence or autonomy requires stronger control.

## Use stronger controls when consequences rise

The six controls stay constant; their intensity changes with the work.

An internal drafting use may need an approved tool, light monitoring, and clear limits on the information entered. The person remains responsible for the note, and the output can be corrected before it affects anyone else. Requiring a formal approval for every draft would add hurdles without a proportionate benefit.

A workflow that feeds a customer-impacting decision needs more. Access should be scoped to the approved use. The organization needs evidence of what informed the decision, a human review point, a named owner, and an escalation path for uncertainty. If the AI can take an action, limits on rate, volume, and permitted actions contain a bad configuration before it travels.

For usage limits, the operating question is how much the AI can do before a person reviews the case or a ceiling stops the run.

Shadow use belongs in the same analysis. When the sanctioned path is so restrictive that it cannot meet a real workflow need, people may choose tools outside it. The approved route has to meet the workflow need and remain easy to find. Monitoring then shows where unmet demand or new dependence on the output requires a change. A high-stakes use may still need to be blocked; leaders can also correct the sanctioned path that people were routing around. This is not a fringe case: in a November 2025 survey of 2,000 U.S. and U.K. employees at companies with more than 500 staff, commissioned by the security vendor BlackFog, 49 percent reported using AI tools their employer had not sanctioned, and 58 percent of those users used free versions.[5]

---

## Start with one usage-control record

Before expanding AI into a high-stakes workflow, require one short usage-control record. It should name the workflow and owner, then answer six questions:

- What work may AI perform, and what access is in scope?
- What usage and outcome signals will be monitored?
- What limits bound volume, rate, or autonomy?
- What evidence and logs must the workflow retain?

- When does a human review or escalation occur, and who can pause or stop the use?
- When will the usage be reviewed again?

Requiring that one record is the change to make. It avoids building a heavy approval process around every user. Low-stakes work can be documented lightly. High-stakes work receives the fuller control set before dependence or autonomy increases.

The record also makes governance continuous. New workflows appear, existing uses scale, and a low-stakes drafting aid may become an input to a decision. NIST treats risk management as work that continues across the lifecycle.[2] At each review, the owner uses observed evidence to change or end the permitted use.

---

## Keep the claim modest

This paper proposes an operating standard. No controlled comparison establishes that workflow governance causes faster adoption or better outcomes than broad access. The McKinsey and NIST sources support context, monitoring, guardrails, and human responsibility. The six-control record remains my proposal.

No universal threshold separates low-stakes from high-stakes work. Organizations must judge the data involved, the consequence of error, how much people depend on the output or how far the AI acts on its own, and the ability to recover. Excessive process can recreate the hurdles that broad access was meant to remove. A weak record leaves high-stakes work exposed. Proportionality requires judgment, evidence, and a named owner.

The record should also earn its place. If it never changes a control decision, simplify it. The purpose is a usable decision at the workflow level.

---

## Make the next access decision differently

Return to the two employees using the same approved tool. The internal drafting use can keep a light path because a person can inspect and correct the output before it matters. The customer-impacting workflow gets the full usage-control record because the consequence is higher.

The organization still expands AI access. It now knows where that access enters real work and what the AI may do there. The control record also shows how a mistake is

contained and who decides when the use changes.

For the next customer-impacting workflow, require the record before dependence or autonomy increases. Let the named owner decide whether the evidence supports a light path, stronger controls, or stopping the use.

---

## Notes and sources

[1] Gabriel Morgan Asaftei, Roger Roberts, Abby Sticha, and Cécile Prinsen, "State of AI trust in 2026: Shifting to the agentic era," McKinsey & Company, March 25, 2026. <https://www.mckinsey.com/capabilities/tech-and-ai/our-insights/tech-forward/state-of-ai-trust-in-2026-shifting-to-the-agentic-era>

[2] National Institute of Standards and Technology, "AI Risk Management Framework Core," AI RMF 1.0, 2023. <https://airc.nist.gov/airmf-resources/airmf/5-sec-core/>

[3] Chloe Autio, Reva Schwartz, Jesse Dunietz, Shomik Jain, Martin Stanley, Elham Tabassi, Patrick Hall, and Kamie Roberts, "Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile," NIST AI 600-1, July 26, 2024. <https://doi.org/10.6028/NIST.AI.600-1>

[4] International Organization for Standardization and International Electrotechnical Commission, "ISO/IEC 42001:2023 — Information technology — Artificial intelligence — Management system," 2023. <https://www.iso.org/standard/42001>

[5] Taryn Plumb, "Roughly half of employees are using unsanctioned AI tools, and enterprise leaders are major culprits," CIO, January 29, 2026. <https://www.cio.com/article/4124760/roughly-half-of-employees-are-using-unsanctioned-ai-tools-and-enterprise-leaders-are-major-culprits.html>

**About the author**

Marco Policani is an enterprise portfolio, PMO, and AI operating-governance leader. He builds portfolio governance systems where AI carries the analytical load and named humans own every decision — an approach documented across case studies, walkthroughs, and working governance guides on his portfolio site.

Portfolio & governance library: [policani.net/governance](https://policani.net/governance) · Full portfolio: [policani.net](https://policani.net) · LinkedIn: [linkedin.com/in/marcpolicani](https://linkedin.com/in/marcpolicani)

This white paper may be shared freely with attribution. © 2026 Marco Policani.